task: system-audit-and-roadmap

created: 2026-11-02

updated: 2026-11-02

status: done

workflow: WF-ARCH

priority: P1

PLAN MASTER: Phân tích Kiến trúc Toàn diện Hệ thống (Ưu/Nhược điểm) & Lộ trình Đề xuất Nâng cấp

> File này CHỈ chứa tổng quan + trạng thái. Chi tiết từng bước (mô tả đầy đủ, Handoff Log, artifact chi tiết) nằm ở `steps/STEP-[N.M]-[tên].md` tương ứng — xem cột "Step file" bên dưới.

Mô tả

Thực hiện đợt khảo sát, kiểm toán kỹ thuật chuyên sâu (Read-only Audit — chưa sửa code) trên toàn bộ hệ thống **KZTEK Work Management** nhằm chuẩn bị cho giai đoạn Golive và mở rộng quy mô sử dụng lớn. Đánh giá khách quan, có dẫn chứng mã nguồn (`file:line`) trên cả 4 mảng:

1. **Web App & Backend**: Kiến trúc Next.js 16 (App Router), REST API, Prisma 7 / PostgreSQL 17 (`PrismaPg`), Bảo mật Auth (JWT + Cookie LAN) / RBAC (`permissions-server.ts`), Hiệu năng (`useTabCache` SWR, `NotificationQueue` bất đồng bộ).
2. **Giao diện, UX & Tính năng nghiệp vụ**: Kanban Board, MyWork đa dự án, Desktop Web Workstation (`/desktop`), bộ soạn thảo WYSIWYG HTML↔Markdown, Customer Ticket Portal (`/portal`).
3. **Ứng dụng C# Avalonia Mobile & Đồng bộ đa nền tảng**: Kiến trúc MVVM trong `mobile/KztekWorkManagement.Mobile/`, mức độ tuân thủ `KztekComponentAvalonia` (Rule R9), và độ đồng bộ API/Model với Web App hiện tại.
4. **Hạ tầng triển khai & Hệ thống điều phối Agent**: Docker / `docker-compose.yml`, vận hành mạng LAN / Production, backup/logging, CI/CD, và cấu trúc điều phối Multi-Agent `.gemini/`.

Từ kết quả phân tích, chỉ rõ **Ưu điểm cốt lõi**, **Nhược điểm / Nợ kỹ thuật / Rủi ro bảo mật – hiệu năng**, và xây dựng **Lộ trình Đề xuất (Quick-wins trước Golive → Ngắn hạn 1–3 tháng → Dài hạn 6–18 tháng)** được CTO thẩm định và phê duyệt qua ADR chính thức.

Nguồn yêu cầu

- Yêu cầu gốc: "Phân tích hệ thống nêu ra ưu diểm , nhược điểm + đề xuất"
- Workflow: `WF-ARCH` — Thiết kế & Đánh giá Kiến trúc Hệ thống
- Agent chain: `TECH LEAD` (Khảo sát & Phân tích kỹ thuật toàn diện) → `CTO` (Thẩm định chiến lược, phê duyệt lộ trình & ký duyệt ADR)

Phases & Steps

> **Session isolation (GEMINI.md §16.5):** Mỗi bước ☐/🔄 PHẢI chạy tách session — LOCAL dùng `Agent` subagent, WEB dùng `RemoteTrigger`. Agent/trigger tự tạo/cập nhật step file riêng, commit+push, rồi cập nhật đúng 1 dòng status ở bảng dưới đây.

Phase 1: Khảo sát Mã nguồn & Phân tích Kỹ thuật Toàn diện

#	Bước	Agent	Status	Step file	Hoàn thành lúc
---	------	-------	--------	----------	----------
1.1	Khảo sát thực tế source code 4 mảng (Web/DB/Auth/Perf, UI/UX/Business, C# Avalonia Mobile, Docker/CI-CD/Agent), chạy checklist `security-audit-stride` (OWASP + STRIDE) & `codebase-design`, xuất Báo cáo Phân tích Kiến trúc & Đề xuất Kỹ thuật	`tech-lead`	✅	`steps/STEP-1.1-tech-lead-system-audit.md`	2026-11-02 16:54

Phase 2: Thẩm định Chiến lược, Phê duyệt Lộ trình & Ban hành ADR

#	Bước	Agent	Status	Step file	Hoàn thành lúc
---	------	-------	--------	----------	----------
2.1	Thẩm định báo cáo của Tech Lead dưới góc nhìn chiến lược công nghệ, đánh giá rủi ro Golive/Scale, chốt ma trận ưu tiên đầu tư (Impact vs Effort) cho 3 giai đoạn và ký duyệt Architecture Decision Record (ADR)	`cto`	✅	`steps/STEP-2.1-cto-strategic-review-adr.md`	2026-11-02 17:01

Artifacts dự kiến (tổng)

- [x] `docs/architecture/ARCH-AUDIT-system-2026-11-02.md` (+ `.docx`, `.pdf` xuất qua `scripts/md_to_docx_kztek.py`)

- [x] `docs/architecture/ADR-001-system-architecture-roadmap.md` (+ `.docx`, `.pdf` xuất qua `scripts/md_to_docx_kztek.py`)
- [x] `docs/plans/PLAN-system-audit-and-roadmap-2026-11-02/PLAN-MASTER.md` & `steps/STEP-*.md` (+ `.docx`, `.pdf` theo Rule R1)

Blockers

Không có

Quyết định / Ghi chú tổng

- **Chế độ Read-Only đối với Source Code:** Tuyệt đối KHÔNG sửa đổi bất kỳ file mã nguồn ứng dụng nào (`src/`, `prisma/`, `mobile/`, `Dockerfile`...) trong phạm vi plan này; chỉ tạo tài liệu báo cáo, ADR và plan files.
- **Chuẩn bằng chứng (Evidence-based Audit):** Mọi nhận định ưu điểm, nhược điểm hoặc lỗ hổng tiềm ẩn đều phải gắn nhãn độ tin cậy (`CONFIRMED` kèm đường dẫn `file:line`, không suy diễn cảm tính từ tài liệu cũ).
- **Quyết định Chiến lược CTO (`ADR-001`):** Phê duyệt có điều kiện (**Phương án B** — Modular Monolith cứng hóa theo cấp độ + Golive 2 tầng: **Tier-1 LAN** sau Phase G0 = `9.0 man-days`, **Tier-2 Public Internet & Mobile R9** sau Phase G1 = `24.0 man-days` có bổ sung PostgreSQL Transactional Outbox `G1-0`, và **Phase G2 = `30.0 man-days`** neo chặt theo ngưỡng KPI thực tế). Giữ nguyên hiệu lực 🛑 `BLOCK GOLIVE` hiện tại cho tới khi hoàn thành Gate 1.
- **Git hygiene trên nhánh hiện tại:** Nhánh `feature/ui-ux-enhancements-and-mywork` đang có `_workspace/` untracked; khi commit các bước của plan này CHỈ `git add` đúng các file thuộc `docs/architecture/` và `docs/plans/PLAN-system-audit-and-roadmap-2026-11-02/`.
- **Đường dẫn script R1 thực tế trên workspace:** Sử dụng `python scripts/md_to_docx_kztek.py <duong-dan-file.md>` (kiểm tra file `.pdf` trên đĩa theo `GOTCHAS.md` G005 nếu gặp cảnh báo RPC Word COM).

Lịch sử cập nhật

Ngày	Cập nhật	Agent
2026-11-02	User xác nhận plan, khởi tạo cấu trúc folder & bắt đầu Bước 1.1	task-planner
2026-11-02	Hoàn thành Bước 1.1: Xuất báo cáo kiểm toán kiến trúc & bảo mật toàn diện (`ARCH-AUDIT-system-2026-11-02`)	tech-lead
2026-11-02	Hoàn thành Bước 2.1 & đóng Plan (`status: done`): CTO thẩm định chiến lược, chốt lộ trình 2-Tier Golive + KPI Gates và ký duyệt `ADR-001-system-architecture-roadmap`	cto

Status icons: ☐ Todo | 🔄 In Progress | ✅ Done | 🛑 Blocked | ⏭ Skipped

Cách đọc nhanh: đọc MASTER trước → nếu cần chi tiết bước cụ thể mới mở step file tương ứng.